

COMPLY White Paper



Operationalizing Compliance Through Unified Controls,
Universal Control Criteria, and Evidence-Driven Artifacts

PART I — CONTEXT AND CORE MODEL

1. Introduction

Organizations operating in regulated environments face an increasingly complex compliance landscape spanning multiple security, privacy, and operational resilience frameworks. Standards such as PCI DSS, ISO/IEC 27002:2022, NIST CSF, NIST SP 800-53 Rev. 5, DORA, GDPR, CIS Controls v8.1, and SOC 2 impose overlapping but differently structured control requirements.

The primary challenge is not the absence of controls, but the lack of a unified, defensible, and auditable mechanism to demonstrate that controls are consistently designed, implemented, operated, and evidenced across frameworks.

This white paper describes a framework-agnostic compliance architecture built on four foundational elements:

- Unified Controls – normalized, canonical control statements derived from all underlying frameworks
- Universal Control Criteria (UCC) – a fixed, auditable set of criteria defining what “complete control implementation” means
- Assurance Dimensions –
- COMPLY Artifacts – structured, evidence-producing artifacts mapped to criteria and assurance dimensions

Together, these components form a closed-loop, evidence-driven compliance system that transforms compliance from documentation into verifiable operational truth.

2. Background and Problem Statement

2.1 The Multi-Framework Compliance Problem

Organizations are commonly required to comply with multiple frameworks simultaneously, including but not limited to:

- PCI DSS v4.x (payment card security)
- ISO/IEC 27002:2022 / 27001:2022 (information security management)
- NIST Cybersecurity Framework (CSF)
- NIST SP 800-53 Rev. 5
- SOC 2 Trust Services Criteria
- CIS Controls v8.1
- DORA (Digital Operational Resilience Act)

COMPLY WHITE PAPER V1.5

- GDPR (data protection and accountability)

Each framework:

- Uses different terminology
- Structures controls differently
- Emphasizes different assurance outcomes

Yet, auditors evaluate controls using fundamentally similar principles: design adequacy, implementation, and operational effectiveness.

2.2 Root Cause of Compliance Failures

Empirical audit experience shows that failures most often arise because:

- Controls are documented but not operational
- Evidence exists but does not demonstrate effectiveness
- Artifacts are disconnected from control intent
- Assurance dimensions (design vs operation) are not distinguished
- Evidence cannot be reused across frameworks

The result is duplicative effort, audit fatigue, and weak defensibility.

3. The Comply Model — a Framework-agnostic Control Architecture

At a minimum, the system consists of five tightly coupled layers:

3.1 Control Statement (Normative Requirement)

A control statement defines:

- What must be achieved
- Why it must be achieved
- At what level (organizational, system, process, or asset)

Example (generic):

“The organization establishes, documents, and maintains information security policies that are approved, communicated, and reviewed at planned intervals.”

This statement is framework-agnostic, but legally and audit-relevant.

3.2 Unified Controls — The Canonical Control Layer

Unified Controls are framework-agnostic, normalized control statements that represent the complete intent of all underlying frameworks without duplicating them.

They are:

- Derived from all controls across PCI DSS, ISO 27002, NIST CSF, NIST 800-53r5, DORA, GDPR, CIS v8.1, and SOC 2
- Deduplicated and normalized
- Written as technology-neutral, outcome-focused statements
- Mappable back to every source framework

A Unified Control answers:

- What must the organization achieve, regardless of framework wording?

Unified Controls are constructed through:

- Semantic analysis of control intent
- Identification of overlapping objectives
- Preservation of regulatory rigor
- Explicit cross-mapping to source controls

This ensures:

- No loss of regulatory intent
- No framework bias
- Complete coverage of all source frameworks

References:

- PCI DSS: <https://www.pcisecuritystandards.org>
- ISO/IEC 27002:2022: <https://www.iso.org/standard/75652.html>
- NIST CSF: <https://www.nist.gov/cyberframework>
- NIST SP 800-53r5: <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>
- DORA: https://finance.ec.europa.eu/regulation-and-supervision/financial-services-legislation/digital-operational-resilience-act-dora_en
- GDPR: <https://gdpr-info.eu>
- CIS Controls v8.1: <https://www.cisecurity.org/controls/v8>
- SOC 2 TSC: <https://www.aicpa.org/resources/article/trust-services-criteria>

3.3 Universal Control Criteria (UCC) – The Completeness Standard

Most compliance failures do not occur because a control is missing. They occur because:

- The control intent is only partially implemented
- Evidence exists but does not prove operational effectiveness
- Artifacts exist but are not traceable to a control requirement
- Auditors cannot determine whether a control is designed, implemented, and operating as required

The Universal Control Criteria establish a uniform evidence completeness standard that applies to all COMPLY artifacts, regardless of framework (ISO, SOC 2, PCI DSS, CIS, NIST, etc.) or domain.

They establish:

- What must exist for a control to be considered fully implemented
- What auditors expect to see as objective evidence
- How consistency and completeness are enforced

The UCC decomposes the control statement into atomic, testable criteria which eliminate ambiguity by answering:

- Is the control properly governed?
- Is it intentionally designed?
- Does it exist in reality?
- Does it operate consistently over time?
- Is it reviewed, measured, and improved?

A control is not compliant unless all *applicable* UCC criteria are satisfied.

There are 25 criteria that function as a minimum completeness baseline (see addendum A). No control is considered compliant unless all *applicable* criteria are satisfied.

This aligns with established audit doctrine used in SOC 2 and ISO 27001 audits:

- Design adequacy
- Existence / implementation
- Operating effectiveness

It transforms compliance from framework-specific check-boxing into a repeatable, control-centric evidence lifecycle.

COMPLY WHITE PAPER VI.5

This reflects how professional auditors actually evaluate controls, particularly in SOC 2 examinations, ISO/IEC 27001 certification audits, and regulatory inspections.

References:

- ISO/IEC 27001:2022 – Clause 9 (Performance Evaluation)
<https://www.iso.org/standard/82875.html>
- AICPA SOC 2 Trust Services Criteria – Common Criteria
<https://www.aicpa.org/resources/article/trust-services-criteria>

3.4 Assurance Dimensions — How Controls are Evaluated

Assurance dimensions are the standard ways auditors and regulators evaluate whether a control truly works, not just whether it exists on paper. They break control assessment into distinct perspectives, so organizations can prove that a control is properly designed, actually implemented, and consistently operating over time.

Each UCC criterion is evaluated across three assurance dimensions:

3.3.1 Design Adequacy

Evidence that the control is:

- intentionally constructed
- has defined scope, objectives, and responsibilities
- is aligned with risk and regulatory requirements.

3.3.2 Existence / Implementation

Evidence that the control is:

- Formally implemented
- Exists in systems, processes, and tools
- Is not merely aspirational or documented.

3.3.3 Operational Effectiveness

Evidence that the control:

- Operates consistently over time
- Produces expected outcomes
- Is monitored and corrected when deviations occur.

COMPLY WHITE PAPER V1.5

These dimensions directly align with SOC 2 control testing methodology and ISO 27001 Clause 9 (performance evaluation).

References:

- Source: <https://www.aicpa.org/resources/toolkit/soc-2-examination-guide>

3.5 Comply artifacts — Evidence as First-class Objects

COMPLY Artifacts are structured, purpose-built evidence objects created or collected to satisfy specific UCC criteria.

Artifacts fall into structured categories, for example:

- Governance artifacts
(policies, standards, procedures, charters)
- Management artifacts
(plans, risk assessments, approvals)
- Configuration evidence
(configuration baselines)
- Operational artifacts
(logs, alerts, tickets, reports)
- Oversight artifacts
(reviews, metrics, dash boards, internal audits)

Artifacts are not generic documents. Each artifact:

- Has a defined evidentiary purpose
- Is mapped to UCC criteria
- Supports one or more assurance dimensions
- Can be reused across frameworks.

Key principle:

Artifacts do not exist independently — they exist to satisfy specific UCC criteria.

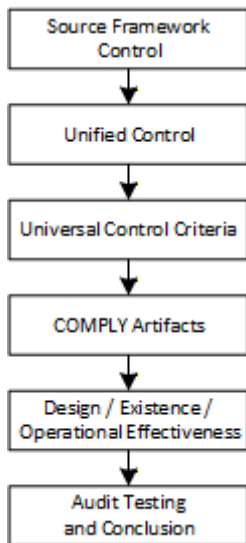
Artifact Reuse and Deduplication

Because Unified Controls are framework-agnostic:

- A single artifact can satisfy multiple frameworks
- Evidence duplication is eliminated
- Audit preparation effort is reduced
- Traceability is strengthened

3.6 End-to-end Traceability Model

The full compliance lifecycle is:



This ensures:

- Every control requirement is traceable
- Every artifact has a purpose
- Every audit conclusion is defensible.

4. Governance, Oversight, and Continuous Compliance

The Comply model enforces continuous compliance by requiring:

- Artifact ownership and accountability
- Versioning and review cycles
- Periodic control effectiveness assessments
- Metrics and KPIs
- Independent internal audit and management review

This aligns with ISO/IEC 27001 continuous improvement principles, SOC 2 monitoring expectations, and regulatory expectations for sustained compliance.

5. Part I Summary

By separating control intent, completeness criteria, and evidence artifacts, this Unified Control Model establishes a durable, scalable, and audit-defensible compliance architecture.

COMPLY WHITE PAPER V1.5

It replaces fragmented, framework-specific compliance with a single operational truth, enabling organizations to demonstrate not just that controls exist—but that they are designed correctly, implemented intentionally, and operating effectively across all required standards.

PART II — A SINGLE, INTEGRATED COMPLIANCE EVIDENCE SYSTEM

1. Introduction

Below is a detailed, end-to-end description of how Universal Control Criteria (UCC), Control Statements, and COMPLY artifacts must operate together as a single, integrated compliance evidence system to ensure that every control implementation produces complete, auditable, and defensible evidence of compliance.

2. How the Components Work Together (Lifecycle View)

2.1 Control Decomposition

Each control statement is decomposed into:

- Applicable UCC criteria (subset or full set of 25)
- Required artifact types per criterion
- Expected evidence characteristics

This ensures:

- No ambiguity in what “compliance” means
- No gaps between control intent and proof

2.2 Artifact Classification by Assurance Dimension

Every artifact must be explicitly classified as supporting one or more of:

- Design testing
- Implementation testing
- Operating effectiveness testing

This mirrors how auditors test controls in SOC 2 and ISO audits.

Reference:

- AICPA SOC 2 Examination Guide
<https://www.aicpa.org/resources/toolkit/soc-2-examination-guide>

2.3 Many-to-Many Evidence Mapping

A single artifact may satisfy:

COMPLY WHITE PAPER V1.5

- Multiple UCC criteria
- Multiple controls
- Multiple frameworks

Conversely:

- A single UCC criterion may require multiple artifacts

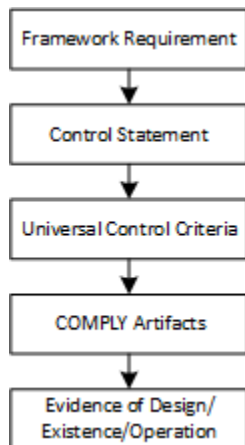
This creates a defensible evidence mesh, not linear documentation.

The Universal Control Model enables:

- Deduplication of evidence
- Cross-framework reuse
- Traceable justification for every artifact

2.4 Evidence Traceability Model

At audit time, the following traceability must be provable:



Each linkage must be:

- Explicit
- Documented
- Machine-readable (for COMPLY / FileMaker)
- Human-defensible (for auditors)

This is consistent with ISO 27001 Annex A traceability expectations and SOC 2 mapping requirements.

Reference:

- ISO/IEC 27002:2022 – Control intent and evidence guidance
<https://www.iso.org/standard/75652.html>

3. Governance and Continuous Compliance

3.1 Artifact Lifecycle Governance

Artifacts are not static. Each artifact must support:

- Versioning
- Ownership
- Review frequency
- Approval history
- Retention rules

This ensures:

- Evidence remains current
- Stale artifacts are detected
- Operational drift is visible

3.2 Control Coverage Assurance

Because every control must satisfy all applicable UCC criteria, the system enables:

- Automated gap detection (missing criteria)
- Partial-compliance flagging
- Objective readiness scoring

This eliminates:

- “Policy-only compliance”
- “Screenshot-only evidence”
- Last-minute audit scrambling

4. Why This Model Is Structurally Sound

The approach aligns with how professional auditors actually think:

- Controls are evaluated holistically
- Evidence is assessed across time
- Weaknesses arise from missing dimensions, not missing documents

COMPLY WHITE PAPER V1.5

By enforcing Universal Control Criteria across all artifacts, you ensure that:

- Compliance is intent-aligned
- Evidence is complete
- Controls are audit-defensible
- Artifacts are reusable and scalable

4.1 Part II Summary

Together, these components form a closed-loop compliance system that transforms compliance from documentation into verifiable operational truth.

PART III — FROM RISK TO CONTROL — ASSET– VULNERABILITY–THREAT–DRIVEN RISK MANAGEMENT

1. Introduction

Effective information security and operational resilience programs must be risk-driven, not control-driven. Controls that are selected without a rigorous understanding of organizational risk frequently result in compliance artifacts that satisfy auditors but fail to reduce real exposure.

The COMPLY Risk Management Process addresses this problem by anchoring compliance and control selection in a structured Asset–Vulnerability–Threat (A–V–T) risk assessment methodology, culminating in a Statement of Applicability (SoA) and the assignment of Unified Controls to mitigate identified risks. It aligns explicitly with internationally recognized standards and regulatory frameworks, like ISO/IEC 27005, NIST risk management principles, and regulatory expectations such as DORA and GDPR.

This process ensures that:

- Risks are identified systematically and defensibly
- Risk treatment decisions are explicit and traceable
- Controls are selected based on risk mitigation needs, not framework checklists
- A Statement of Applicability (SoA) is produced that is meaningful, auditable, and operational

Controls are assigned from a framework-agnostic Unified Controls library, ensuring coverage across PCI DSS, ISO/IEC 27002:2022, NIST CSF, NIST SP 800–53 Rev. 5, CIS Controls v8.1, SOC 2, DORA, and GDPR

2. Foundations of the COMPLY Risk Management Process

2.1 Risk–Driven Compliance as a First Principle

The COMPLY methodology adopts the principle that:

- Controls exist to mitigate risk, not to satisfy frameworks.

This aligns with:

- ISO/IEC 27001:2022 Clause 6.1 (Actions to address risks and opportunities)
<https://www.iso.org/standard/82875.html>

COMPLY WHITE PAPER V1.5

- ISO/IEC 27005:2022 (Information security risk management)
<https://www.iso.org/standard/80585.html>
- NIST SP 800-30 (Risk Assessment)
<https://csrc.nist.gov/publications/detail/sp/800-30/rev-1/final>

2.2 Asset Identification — Establishing What Must Be Protected

An asset is anything that has value to the organization and whose compromise could result in harm. COMPLY adopts a comprehensive, multi-dimensional asset model, including but not limited to:

- Information assets (data, records, intellectual property)
- Technology assets (systems, applications, infrastructure)
- Network and communication assets
- Cloud and virtualized assets
- People and roles
- Business processes
- Facilities and environmental assets
- Third-party and external dependencies

Each asset is:

- Classified (confidentiality, integrity, availability)
- Assigned an owner
- Contextualized within business processes

This step establishes the risk scope and impact baseline.

2.3 Vulnerability Identification — Understanding Weaknesses

A vulnerability is a weakness that could be exploited by a threat to harm an asset. Vulnerabilities may be:

- Technical (e.g., misconfigurations, unpatched systems)
- Process-related (e.g., lack of monitoring, weak change control)
- Organizational (e.g., unclear responsibilities)
- Human (e.g., lack of training)
- Third-party related

COMPLY maintains structured vulnerability catalogs, aligned with:

- ISO/IEC 27002:2022 control intent

COMPLY WHITE PAPER V1.5

- CIS Controls v8.1 safeguard logic
<https://www.cisecurity.org/controls/v8>
- NIST SP 800-53 control families
<https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>

Vulnerabilities are mapped explicitly to assets, creating a one-to-many relationship.

2.4 Threat Identification — Understanding Adversarial and Non-Adversarial Events

A threat is a potential cause of an unwanted incident that exploits a vulnerability to harm an asset.

Threat categories include:

- Malicious threats (external attackers, insiders)
- Accidental threats (human error, misconfiguration)
- Environmental threats (fire, flood, power failure)
- Technical threats (system failure, software defects)
- Regulatory and legal threats (non-compliance consequences)

Threat modeling follows principles from:

- ISO/IEC 27005
- NIST SP 800-30
- ENISA threat taxonomies (used in DORA contexts)

Each threat is linked to specific vulnerabilities, forming the core A-V-T risk triad.

2.5 Risk Identification and Analysis

In COMPLY, a risk exists when:

- Asset + Vulnerability + Threat → Potential Impact

Each risk scenario is documented with:

- Asset(s) affected
- Vulnerability exploited
- Threat actor or event
- Business, legal, operational, and reputational impact

2.6 Risk Evaluation

COMPLY WHITE PAPER V1.5

Risks are evaluated using defined criteria, typically including:

- Likelihood (probability of occurrence)
- Impact (severity of consequence)
- Inherent risk level
- Risk appetite and tolerance alignment

This aligns with:

- ISO/IEC 27005
- ISO/IEC 31000 (Risk management principles)
<https://www.iso.org/iso-31000-risk-management.html>
- DORA requirements for ICT risk management
https://finance.ec.europa.eu/dora_en

2.7 Risk Treatment — Deciding What to Do About Risk

For each risk, management selects one or more treatment options:

- Mitigate (apply controls)
- Accept (explicit acceptance)
- Transfer (insurance, contractual transfer)
- Avoid (eliminate the activity)

Only mitigated risks require control assignment, but all decisions must be justified and documented.

2.8 Control Assignment Using Unified Controls

COMPLY assigns controls from a Unified Controls framework that is:

- Framework-agnostic
- Derived from PCI DSS, ISO/IEC 27002:2022, NIST CSF, NIST SP 800-53r5, CIS v8.1, SOC 2, DORA, and GDPR
- Normalized and deduplicated
- Outcome-focused rather than prescriptive

This ensures:

- No framework gaps
- No duplicate controls
- Full regulatory coverage

2.9 Mapping Controls to Risks

Controls are assigned based on their ability to:

- Reduce likelihood (preventive/detective controls)
- Reduce impact (corrective/resilience controls)
- Improve detection and response

Each control assignment is explicitly linked to:

- The risk(s) it mitigates
- The vulnerability addressed
- The threat(s) reduced

This establishes risk-to-control traceability, a key audit expectation under ISO 27001 and SOC 2.

2.10 Statement of Applicability (SoA)

The Statement of Applicability (SoA) is the authoritative document that:

- Lists all Unified Controls
- States whether each control is:
 - Applicable
 - Implemented
 - Planned
 - Excluded
- Provides a justification for each decision
- References the risks driving applicability

In COMPLY:

- Controls appear in the SoA because risks exist
- Exclusions are justified by risk acceptance, not convenience
- Each included control maps back to one or more risks

This produces an SoA that is Risk-Driven, not Checklist-Driven which auditors view as credible, defensible, and mature.

ISO reference:

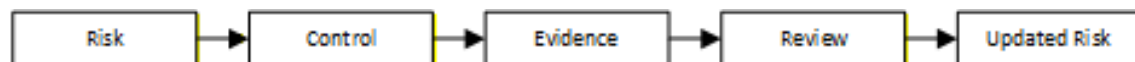
- ISO/IEC 27001:2022 Annex A and Clause 6.1.3
<https://www.iso.org/standard/82875.html>

3. Integration with Control Evidence and Continuous Compliance

Once controls are selected:

- They are implemented following Universal Control Criteria
- Evidence is produced via COMPLY Artifacts
- Effectiveness is monitored continuously
- Risks are reassessed periodically

This closes the loop between:



4. Key Benefits of the Risk-to-Control Process

4.1 Strategic Benefits

- True risk-based compliance
- Regulatory defensibility
- Executive transparency

4.2 Operational Benefits

- Elimination of unnecessary controls
- Efficient control selection
- Clear implementation priorities

4.3 Audit Benefits

- Explicit risk-to-control traceability
- Strong SoA justification
- Reduced audit friction

5. Part III Summary

The COMPLY Risk Management process ensures that controls are the consequence of risk, not the starting point. By grounding compliance in a structured Asset-Vulnerability-Threat model, and by assigning Unified Controls only where they meaningfully reduce risk, organizations achieve:

- Stronger security outcomes

COMPLY WHITE PAPER V1.5

- Lower compliance overhead
- Higher audit confidence
- Sustainable, continuous compliance

This approach represents best practice risk-driven governance aligned with modern regulatory and assurance expectations.

PART IV — THE OPTIMAL COMPLY INTEGRATION MODEL

1. Introduction

Integration of the COMPLY Risk Management process, the Unified Controls framework, the Universal Control Criteria (UCC), and COMPLY Artifacts into a single coherent operating model.

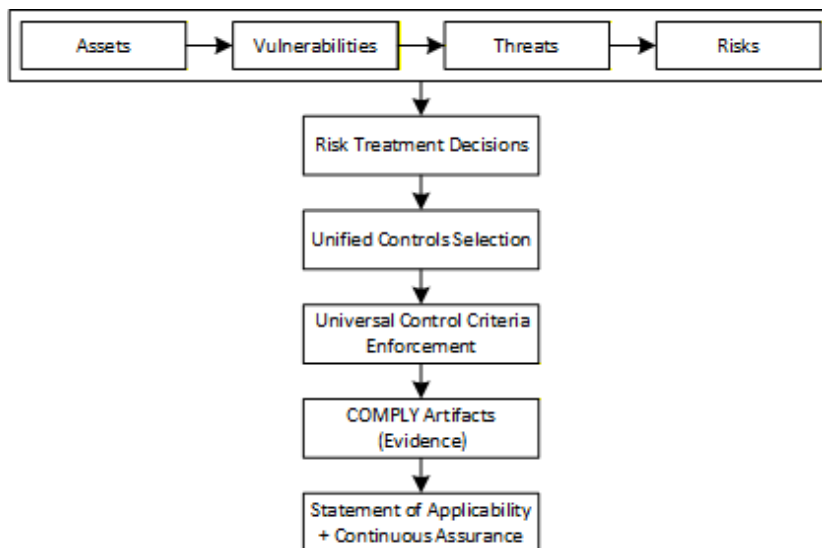
2. Guiding Integration Principle

The single most important integration principle is this:

- Risk is the driver, Unified Controls are the response, UCC defines completeness, and COMPLY Artifacts prove reality.

Any integration that violates this order will eventually degrade into checklist compliance.

The correct flow is therefore:



This mirrors how ISO 27001, SOC 2, NIST, and regulators expect systems to operate in practice, even if frameworks describe them separately.

3. Structural Integration — What Must Be “Primary” vs “Derived”

3.1 Primary Objects (Authoritative Sources)

These should be treated as authoritative system-of-record objects:

COMPLY WHITE PAPER V1.5

- Assets
- Vulnerabilities
- Threats
- Risks
- Unified Controls
- Universal Control Criteria

Everything else is derived.

This aligns with:

- ISO/IEC 27005 (risk-first model)
<https://www.iso.org/standard/80585.html>
- ISO/IEC 27001 Clause 6.1
<https://www.iso.org/standard/82875.html>

3.2 Derived Objects (Outputs, Not Inputs)

These are results, not starting points:

- Statement of Applicability (SoA)
- Control implementation plans
- Policies and procedures
- Evidence artifacts
- Audit reports

Common mistake: starting with policies or SoA templates.

Correct approach: generate them from risk and control logic.

3.3 Integration Step-by-Step (Best Practice)

Step 1: Anchor Everything in the A-V-T Risk Model

The Asset–Vulnerability–Threat model must be the single intake mechanism for compliance.

Best practice integration rule:

- No control may be selected unless it mitigates an identified risk.
- No risk may be treated without referencing assets, vulnerabilities, and threats.

This is explicitly required under:

COMPLY WHITE PAPER V1.5

- ISO 27001:2022 Clause 6.1
- DORA ICT Risk Management requirements
https://finance.ec.europa.eu/dora_en

Step 2: Treat Unified Controls as the ONLY Control Library

Unified Controls should be the exclusive control vocabulary used across:

- Risk treatment
- SoA generation
- Control implementation
- Evidence mapping
- Audit reporting

Framework-specific controls (PCI, ISO, NIST, CIS, SOC 2, etc.) should never be implemented directly—they are mapped, not executed.

This ensures:

- Framework agnosticism
- No duplication
- Guaranteed coverage

References:

- ISO/IEC 27002:2022 intent-based controls
<https://www.iso.org/standard/75652.html>
- NIST CSF 2.0 outcome orientation
<https://www.nist.gov/cyberframework>

Step 3: Bind Risk Treatment Decisions to Unified Controls

Each risk treatment decision must explicitly state:

- Risk ID(s)
- Treatment option (mitigate / accept / transfer / avoid)
- Unified Control(s) selected to mitigate the risk
- Residual risk rationale

This creates risk-to-control traceability, which is a core audit expectation in:

- ISO 27001
- SOC 2
- NIST SP 800-53 governance models

COMPLY WHITE PAPER V1.5

- Source:
<https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>

Step 4: Auto-Generate the Statement of Applicability (SoA)

The SoA should be generated, not authored manually.

Best integration approach:

- Every Unified Control appears in the SoA
- Applicability is driven by whether a risk exists that the control mitigates
- Exclusions are justified by risk acceptance or irrelevance, not convenience

This produces a defensible, regulator-grade SoA, as required by:

- ISO/IEC 27001 Clause 6.1.3
<https://www.iso.org/standard/82875.html>

4. Universal Control Criteria as the Enforcement Layer

4.1 UCC Must Be Mandatory and Non-Negotiable

Once a Unified Control is applicable, all UCC criteria apply unless explicitly justified.

Best practice:

- Do not allow “partial controls”
- Do not allow evidence without UCC mapping
- Do not allow policies without operational artifacts

This enforces:

- Design adequacy
- Implementation existence
- Operational effectiveness

This mirrors:

- SOC 2 control evaluation logic
<https://www.aicpa.org/resources/article/trust-services-criteria>

4.2 UCC as a Quality Gate

UCC should act as a quality gate:

- A control cannot be marked “implemented” unless all applicable UCC criteria are satisfied
- A control cannot be “effective” unless operational evidence exists

This prevents:

- Policy-only compliance
- Tool-only compliance
- Audit surprises

5. COMPLY Artifacts as the Evidence Backbone

5.1 Artifact Creation Must Be Criterion-Driven

Artifacts should never be created ad hoc.

Best integration rule:

- Every artifact must map to:
- One or more UCC criteria
- One or more Unified Controls
- One or more risks (indirectly)

This enables:

- Evidence reuse across frameworks
- Clear audit narratives
- Reduced documentation volume

5.2 Treat Evidence as a Lifecycle, Not a Snapshot

Artifacts must support:

- Ownership
- Review frequency
- Versioning
- Retention
- Integrity

COMPLY WHITE PAPER V1.5

This aligns with:

- ISO 27001 continuous improvement
- SOC 2 monitoring requirements
- DORA resilience expectations

6. Governance Model for Sustainable Integration

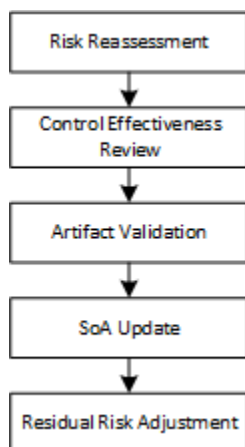
6.1 Ownership Model

Best practice ownership alignment:

- This separation prevents conflicts of interest and improves audit defensibility.

6.2 Continuous Feedback Loop

The system must continuously loop:



This is explicitly expected under:

- ISO/IEC 27001 Clause 9 & 10
- DORA ongoing risk management

7. What “Good Integration” Looks Like in Practice

If integration is done correctly:

- The SoA changes when risks change
- Controls exist only where risks exist
- Evidence always has a purpose
- Auditors can trace: Risk → Control → Criteria → Artifact → Evidence

Framework mappings become reporting views, not implementation drivers

8. What to Avoid (Common Anti-Patterns)

Avoid:

- Framework-by-framework implementations
- Manual SoA maintenance
- Evidence collected “just for audit”
- Controls without risks
- Risks without controls

These patterns are explicitly criticized in modern audits and regulatory reviews.

9. Part IV Summary

The best way to integrate COMPLY is to treat it as a single operating system, not a set of modules.

- Risk is the entry point
- Unified Controls are the only control language
- UCC enforces completeness
- COMPLY Artifacts prove reality
- The SoA is an output, not a starting document

This integration model is fully aligned with ISO, NIST, SOC 2, DORA, GDPR, PCI DSS, and CIS expectations, while remaining scalable, auditable, and defensible.

ADDENDA

A. UNIVERSAL CONTROL CRITERIA

Criterion ID	Universal Control Criteria Name
UCC-01	The organization identifies and assesses risks using a formal methodology and documents the results.
UCC-02	The organization maintains a centralized, version-controlled Risk Register that captures all identified risks with ownership and status.
UCC-03	The organization defines and documents risk treatment options, including mitigation, transfer, acceptance, or avoidance.
UCC-04	The organization documents the selection of controls and provides justification aligned with risk treatment and compliance needs.
UCC-05	The organization identifies all applicable compliance and regulatory requirements relevant to its operations.
UCC-06	The organization establishes and maintains alignment between identified risks and corresponding controls.
UCC-07	The organization identifies differences between current practices and framework requirements.
UCC-08	The organization designs controls specifically to address identified risks and documents the design.
UCC-09	The organization formally documents each control in approved policy, standard, or procedure documents.
UCC-10	The organization assigns clear ownership and accountability for each control to designated individuals or roles.
UCC-11	The organization defines and enforces segregation of duties to prevent conflicts of interest and unauthorized activities.
UCC-12	The organization establishes alignment between internal controls and applicable external compliance requirements.
UCC-13	The organization formally documents each control in approved policy, standard, or procedure documents.
UCC-14	The organization implements controls as designed and ensures they are fully operational.
UCC-15	The organization enforces access and authorization controls to ensure least privilege and proper user rights.

COMPLY WHITE PAPER V1.5

Criterion ID	Universal Control Criteria Name
UCC-16	The organization reviews and approves critical security and compliance processes to ensure they remain fit-for-purpose, effective, and aligned with business, regulatory, and risk management objectives.
UCC-17	The organization documents and manages exceptions to established controls in an approved exception register.
UCC-18	The organization communicates control requirements and responsibilities to all relevant stakeholders.
UCC-19	The organization retains evidence of control activities in accordance with policy and regulatory requirements.
UCC-20	The organization demonstrates the operational effectiveness of controls through monitoring, testing, and reporting.
UCC-21	The organization consistently applies controls across all relevant systems, processes, and business units.
UCC-22	The organization ensures that control effectiveness is tested.
UCC-23	The organization ensures that continuous improvement is performed.
UCC-24	The organization ensures that control is monitored and reviewed regularly.
UCC-25	The organization ensures that control adapts to changes.

B. FORMAL UCC APPLICABILITY RULES

1. Introduction

Below is a formal, rule-based UCC Applicability Framework designed specifically for COMPLY / Universal Control Model (UCF) automation. It is written to be machine-enforceable, auditor-defensible, and scalable across all control domains (governance, risk, technical, operational).

2. Core Design Principles (Non-Negotiable)

- UCCs are evaluation criteria, not mandatory per-control requirements
- Control intent determines applicability
- Lifecycle alignment governs expectation
- Inheritance is valid and auditable
- "Explicit" requires direct evidence owned by the control
- "N/A" must be logically justified, not omitted

These principles align with ISO/IEC 27001, SOC 2, and NIST SP 800-53 assessment models.

References

- ISO/IEC 27001 overview: <https://www.iso.org/isoiec-27001-information-security.html>
- SOC 2 TSC design vs. operating effectiveness: <https://www.aicpa.org/resources/landing/soc-2>
- NIST SP 800-53 Rev. 5 assessment logic: <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>

3. Control Classification Inputs (Required for Automation)

Every UCF control must be pre-classified using the following metadata fields:

Field	Allowed Values
Control Layer	Governance / Risk / Technical / Operational
Control Nature	Directive / Preventive / Detective / Corrective
Lifecycle Stage	Design / Existence / Operational Effectiveness
Control Scope	Enterprise / Process / System / Asset
Control Dependency	Standalone / Dependent
Evidence Owner	Policy / Process / System / Hybrid

These fields drive all UCC applicability decisions.

4. Universal Applicability Decision Model (High-Level)

For each UCC X and Control Y, apply this logic in order:

- IF UCC intent is directly stated in Control Y
→ Applicability = Explicit
- ELSE IF UCC intent is satisfied by a referenced or dependent control
→ Applicability = Inherited
- ELSE IF UCC intent is logically irrelevant to Control Y's layer or nature
→ Applicability = Not Applicable
- ELSE
→ Flag as Modeling Error (requires control reclassification)

4.1 Formal Rule Sets by UCC Category

A. Risk & Alignment UCCs (UCC-01 to UCC-07)

UCC	Explicit Rule	Inherited Rule	N/A Rule
UCC-01 Risk assessment	Control performs risk identification	Control references risk outputs	Policy-only control
UCC-02 Risk register	Control maintains register	Control consumes register	Governance-only control
UCC-03 Risk treatment	Control selects treatment	Treatment defined elsewhere	Directive-only control
UCC-04 Control selection	Control selects controls	Selection via SoA	Pure execution control
UCC-05 Compliance obligations	Control identifies obligations	Register exists elsewhere	Technical-only control
UCC-06 Risk-control alignment	Control performs mapping	Mapping elsewhere	Single-purpose control
UCC-07 Gap identification	Control identifies gaps	Audit/assessment controls	Policy authoring control

Automation default:

- Governance controls → Inherited or N/A
- Risk controls → Explicit

B. Control Design & Documentation UCCs (UCC-08 to UCC-13)

COMPLY WHITE PAPER V1.5

UCC	Explicit Rule	Inherited Rule	N/A Rule
UCC-08 Control design	Control defines design	Design referenced	Runtime-only control
UCC-09 Documentation	Control requires documentation	Document exists elsewhere	Fully automated control
UCC-10 Ownership	Control assigns owner	RACI elsewhere	Embedded system control
UCC-11 SoD	Control defines SoD	IAM/process controls	Informational control
UCC-12 External alignment	Control maps frameworks	Mapping elsewhere	Asset-level control
UCC-13 Procedures	Control mandates procedures	SOP elsewhere	Policy-only control

Automation default:

- Governance & Risk controls → Explicit
- Technical controls → Inherited

C. Implementation & Access UCCs (UCC-14 to UCC-15)

UCC	Explicit Rule	Inherited Rule	N/A Rule
UCC-14 Implementation	Control implements itself	Implemented downstream	Policy control
UCC-15 Access control	Control enforces access	IAM enforces	Non-access control

Automation default:

- Technical controls → Explicit
- Governance controls → N/A

D. Governance, Review & Evidence UCCs (UCC-16 to UCC-19)

UCC	Explicit Rule	Inherited Rule	N/A Rule
UCC-16 Approval	Control requires approval	Governance process	Autonomous control
UCC-17 Exceptions	Control manages exceptions	Central register	Hard-mandatory control

COMPLY WHITE PAPER V1.5

UCC	Explicit Rule	Inherited Rule	N/A Rule
UCC-18 Communication	Control mandates comms	Training program	Silent control
UCC-19 Evidence retention	Control generates evidence	Central retention	Stateless control

Automation default:

- Governance controls → Explicit
- Technical controls → Inherited

E. Effectiveness, Improvement & Change UCCs (UCC-20 to UCC-25)

UCC	Explicit Rule	Inherited Rule	N/A Rule
UCC-20 Monitoring	Control monitors itself	SOC/KPI monitoring	Policy-only
UCC-21 Consistency	Control enforces uniformity	Enterprise controls	Single-system
UCC-22 Testing	Control includes testing	Audit controls	Informational
UCC-23 Improvement	Control mandates improvement	CAPA process	Static control
UCC-24 Review	Control mandates review	Management review	One-time control
UCC-25 Adaptation	Control adapts to change	Change mgmt	Immutable control

Automation default:

- Operational controls → Explicit
- Governance controls → Explicit (review/update only)

4.2 Mandatory Automation Safeguards

Completeness Rule

Every control must have:

- At least one Explicit UCC or
- At least one Inherited UCC per lifecycle stage

Otherwise → Modeling error

Proportionality Rule

- No control may have all UCCs marked Explicit. This indicates over-modeling.

Justification Rule

Every Inherited or N/A classification must store:

- justification_type
- justification_text
- source_control_reference (if inherited)

5. Why This Works for Auditors

- Mirrors ISO 27001 clause applicability logic
- Matches SOC 2 design vs. operating effectiveness testing
- Aligns with NIST assessment objectives
- Prevents artificial control inflation
- Enables deterministic, repeatable assessments

C. COMPLY ARTIFACT GENERATION METHODOLOGY

Introduction

Below is a repeatable, audit-defensible method to generate a complete and non-overlapping set of COMPLY artifacts from any detailed control statement, ensuring full Design, Existence, and Operational Effectiveness coverage and explicit alignment with Universal Control Criteria (UCC).

This approach is framework-agnostic and works for SOC 2, ISO/IEC 27001/27002, PCI DSS, NIST, CIS, DORA, GDPR, and NIS2.

13.1 Executive Summary

A complete set of COMPLY Artifacts is generated by decomposing the control statement into obligations, mapping each obligation to Universal Control Criteria, deriving lifecycle processes (Design / Existence / Operational Effectiveness), and materializing each process output as a concrete, reviewable artifact.

13.2 Step-by-Step Methodology

STEP 1 — DECOMPOSE THE CONTROL STATEMENT INTO ATOMIC OBLIGATIONS

Break the control statement into atomic requirements, typically using verbs and qualifiers.

Example verbs to extract

- Identify
- Define
- Document
- Approve
- Implement
- Monitor
- Review
- Test
- Improve

Output:

A list of atomic control obligations, each expressing one measurable expectation.

Why this matters: Auditors test obligations, not prose

Normative Rule — Obligation Anchoring

An obligation shall be created only when the control statement contains an explicit, testable verb that mandates an action.

COMPLY WHITE PAPER V1.5

Obligations MUST NOT be inferred from:

- Common practice
- Typical control implementations
- Artifacts that usually exist
- Downstream process outputs

If an expectation is not explicitly stated or logically unavoidable from the control text, it shall Not be treated as an obligation.

.

STEP 2 — MAP EACH OBLIGATION TO UNIVERSAL CONTROL CRITERIA (UCC)

For each atomic obligation, determine which UCC(s) it satisfies.

Typical mapping patterns:

Output:

An Obligation → UCC mapping table.

Reference (UCC definitions):

- COMPLY - UCC - Universal Control Criteria - 121725

STEP 3 — CLASSIFY EACH OBLIGATION BY CONTROL LIFECYCLE STAGE

Each obligation must fall into exactly one of the following:

- Design
- Existence
- Operational Effectiveness

Rule: If an obligation cannot be placed in one stage, it is underspecified.

STEP 4 — CONVERT OBLIGATIONS INTO PROCESSES

For each obligation, define a process, not an artifact.

Process definition includes

- Purpose
- Trigger
- Roles
- Inputs
- Activities
- Outputs

COMPLY WHITE PAPER VI.5

Rule: Each obligation maps to exactly one lifecycle stage.

Example

Obligation: "Risks are formally identified and documented"

Process: "Perform periodic risk assessments"

Output:

A Process Catalog, grouped by Design / Existence / Operational Effectiveness

STEP 5 – DERIVE ARTIFACTS FROM PROCESS OUTPUTS (NOT INPUTS)

Critical rule:

Evidence artifacts are outputs of processes, never activities themselves.

For each process, ask:

What does an auditor expect to see, review, or sample?

Artifact quality criteria

- Persistent (saved)
- Reviewable
- Versioned or time-bound
- Attributable to owners
- Independently verifiable

Examples

Process: Risk Assessment

→ Artifact: Risk Assessment Report

Process: Control Monitoring

→ Artifact: KPI / Monitoring Report

Process: Control Testing

→ Artifact: Test Plan + Test Results

STEP 6 – ASSURANCE DIMENSION COVERAGE

For each Assurance Dimension indicate if it is covered and if so, by what evidence. Apply the rules below:

Rules:

- Design Adequacy SHALL apply to any control that mandates the definition, establishment, documentation, approval, or governance of a control objective, regardless of whether the control mandates technical or operational implementation.
- Design Adequacy SHALL NOT be waived on the basis that a control is "policy-only," "governance-only," or "directive in nature."

COMPLY WHITE PAPER V1.5

- Existence is a conditional assurance dimension that applies exclusively to controls that mandate the implementation of a verifiable mechanism. Governance and directive controls SHALL NEVER be evaluated on Existence, regardless of documentation maturity or approval status.
- Operational Effectiveness SHALL apply exclusively to controls that mandate ongoing execution, monitoring, review, or adaptive behavior over time.
- Governance and directive controls SHALL be evaluated on Operational Effectiveness when they explicitly require periodic review, oversight, monitoring, or adaptation—regardless of whether they mandate a technical mechanism.
- Operational Effectiveness SHALL NOT apply to one-time, static, or point-in-time controls that do not require ongoing action after initial design or approval.

STEP 7 — VALIDATE COVERAGE USING A TRACEABILITY MATRIX

Create a four-way traceability matrix:

Obligation → UCC → Process → Artifact.

Validation checks

- Every obligation maps to one or more artifacts
- Every applicable UCC (01–25) is covered
- No artifact exists without a process
- No process exists without a control obligation



This is the completeness proof.

STEP 8 — APPLY AUDIT SUFFICIENCY TESTS

Before finalizing, test each artifact against auditor expectations:

- All control obligations have been decomposed.
- All Explicit UCCs are evidenced.
- No artifact exists without a process.
- No process exists without an obligation.
- The control is auditable across Design, Existence, and Operational Effectiveness.
- Artifacts that fail sufficiency tests must be enhanced or split.

13.3 Final Output That Should Always Be Produced

- Control Obligation Decomposition
- Obligation → UCC Mapping

COMPLY WHITE PAPER V1.5

- Process Catalog (Design / Existence / Operational Effectiveness)
- Process → Artifact Traceability Matrix
- Final Evidence Artifact Register
- Coverage & Gap Analysis (0 gaps)

This structure is universally accepted by auditors

13.4 Why This Method Works in Practice

- Aligns with ISO/IEC 27001 clause logic
- Mirrors SOC 2 auditor walkthroughs
- Prevents over- or under-collection of evidence
- Scales cleanly across frameworks
- Automates well in GRC and FileMaker systems

References

- ISO/IEC 27001 overview
<https://www.iso.org/isoiec-27001-information-security.html>
- AICPA SOC 2 guidance
<https://www.aicpa.org/resources/landing/soc-2>
- NIST SP 800-53 control lifecycle
<https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>

Mandatory Output Structure (NON-NEGOTIABLE)

Every control MUST be produced in the following 10 sections, in this exact order.

No sections may be omitted.

If a section is not applicable, it must explicitly state “Not Applicable – Justified”.

SECTION 1 — CONTROL IDENTIFICATION

Fixed Fields (always present):

Field	Value
Control ID	<UCF ID>
Control Name	<Control Name>
Control Statement	<Verbatim Control Statement>
Control Layer	Governance / Risk / Technical / Operational
Control Nature	Directive / Preventive / Detective / Corrective

COMPLY WHITE PAPER V1.5

Field	Value
Control Scope	Enterprise / Process / System / Asset
Primary Assurance Focus	Design / Existence / Operational Effectiveness

SECTION 2 — ATOMIC OBLIGATION DECOMPOSITION

Rule:

Only verbs explicitly present in the control statement may generate obligations.

Mandatory Table:

Obligation ID	Obligation Statement	Extracted Verb
O-01	...	Defines
O-02	...	Approves
O-03	...	Communicates
O-04	...	Reviews

SECTION 3 — OBLIGATION → UCC MAPPING

List Rule:

This is the only place where UCC Explicit eligibility is established.

Use the verbatim Universal Control Criteria Name for “UCC Name”

Mandatory Table:

Obligation ID	UCC ID	UCC Name	Mapping Type
O-01	UCC-08	Control design	Explicit
O-02	UCC-16	Review & approval	Explicit
O-03	UCC-18	Communication & awareness	Explicit
O-04	UCC-24	Ongoing review	Explicit

SECTION 4 — LIFECYCLE CLASSIFICATION

List Rule: Each obligation maps to exactly one lifecycle stage.

Mandatory Table:

COMPLY WHITE PAPER V1.5

Obligation ID	Obligation Statement	Lifecycle Stage
O-01		Design
O-02		Design
O-03		Existence
O-04		Operational Effectiveness

SECTION 5 – PROCESS DERIVATION

Ordered by Life-cycle Stage.

Rule:

Obligations generate processes, never artifacts.

Mandatory Table:

Process ID	Process Name	Lifecycle Stage	Derived From Obligation
P-D-01	Define Information Security Policy	Design	O-01
P-D-02	Approve Information Security Policy	Design	O-02
P-E-01	Communicate Information Security Policy	Existence	O-03
P-O-01	Review & Update Information Security Policy	Operational Effectiveness	O-04

SECTION 6 – ARTIFACT DERIVATION (OUTPUTS ONLY)

Ordered by Life-cycle Stage.

Rule:

Artifacts are outputs of processes, never inputs or activities.

Mandatory Table:

Artifact ID	Artifact Name	Artifact Type	Produced By Process
ART-01	Approved Information Security Policy	Policy	P-D-01
ART-02	Policy Approval Record	Approval Evidence	P-D-02

COMPLY WHITE PAPER V1.5

Artifact ID	Artifact Name	Artifact Type	Produced By Process
ART-03	Policy Communication Log	Communication Evidence	P-E-01
ART-04	Policy Review & Update Log	Review Evidence	P-O-01

SECTION 7 – ARTIFACT → UCC COVERAGE MATRIX

Rule:

Every Explicit UCC must be covered by ≥1 artifact.

Mandatory Table:

Artifact ID	UCC ID	UCC Name	Coverage Type
ART-01	UCC-08	Control design	Direct
ART-02	UCC-16	Review & approval	Direct
ART-03	UCC-18	Communication & awareness	Direct
ART-04	UCC-24	Ongoing review	Direct

SECTION 8 – UCC APPLICABILITY SUMMARY

Rule:

Explicit eligibility comes only from Section 3.

Mandatory Table (ALL UCCs 01–25):

UCC ID	UCC Name	Applicability	Justification
UCC-01	Risk identification & assessment	N/A	Governance policy control
UCC-08	Control design	Explicit	Policy definition obligation
UCC-18	Communication & awareness	Explicit	Explicitly required
...	...	...	...

SECTION 9 – ASSURANCE DIMENSION COVERAGE

Mandatory Table:

Assurance Dimension	Covered	Evidence
Design Adequacy	–	ART-01, ART-02
Existence	–	ART-03

COMPLY WHITE PAPER V1.5

Assurance Dimension	Covered	Evidence
Operational Effectiveness	-	ART-04

SECTION 10 — VALIDATE COVERAGE USING A TRACEABILITY MATRIX

Create a four-way traceability matrix:

Obligation	UCC	Process	Artifact
-	-	-	-
-	-	-	-
-	-	-	-

SECTION 10 — COMPLETENESS & AUDIT ASSERTION

Indicate which of the following completeness statements apply:

- All control obligations have been decomposed.
- All Explicit UCCs are evidenced.
- No artifact exists without a process.
- No process exists without an obligation.
- The control is auditable across Design, Existence, and Operational Effectiveness.

Criterion	Status
All control obligations have been decomposed.	-
All Explicit UCCs are evidenced.	-
No artifact exists without a process.	-
No process exists without an obligation.	-
The control is auditable across Design, Existence, and Operational Effectiveness.	-

Define the Final Control Status, based on the completeness statements above:

- ☐ Incomplete
- ☐ Partially Implemented
- ☐ Fully Implemented (Evidence-Complete)

Enforcement Rules (CRITICAL)

- No Section Omission Rule

COMPLY WHITE PAPER V1.5

- Every section must exist, even if marked N/A.
- Single Source of Explicit Truth Rule
 - UCC Explicit classification may only originate in Section 3.
- Zero Inference Rule
 - No obligations, processes, or artifacts may be inferred.

Why This Guarantees Identical Output

- Fixed section order
- Fixed table schemas
- Fixed rule boundaries
- No narrative-driven branching
- No analyst discretion points

This makes COMPLY:

- Deterministic
- Auditor-repeatable
- Machine-enforceable
- Framework-agnostic

References

- ISO/IEC 27001:2022 — Control lifecycle & evidence expectations
 - <https://www.iso.org/isoiec-27001-information-security.html>
- AICPA SOC 2 Examination Guide — Design vs. operating effectiveness
 - <https://www.aicpa.org/resources/toolkit/soc-2-examination-guide>

COMPLY WHITE PAPER V1.5

END OF DOCUMENT